

DSG Software Security and Penetration Testing

SSO Configuration Check Report

Application	Report and Retain	PPA #	834561
Pen Test Type	Pre-Production	RP #	900296
Assessment Date	07/07/2025	PTI#	900295
Report Type	Preliminary	Report Date	07/09/2025

THIS REPORT IS DELIVERED TO THE CLIENT TO ASSIST WITH VULNERABILITY REMEDIATION ACTIVITIES. THIS REPORT DOES NOT CARRY AN ENDORSEMENT FROM THE SOFTWARE SECURITY AND PEN TEST TEAM

This report is for KPMG internal use only and its content cannot be shared or distributed in any form with a third party client or vendor without initiating the client inquiry process or obtaining appropriate vendor report.

Assessment Timelines

Assessment Start Date	7 th July, 2025
Assessment Completion Date	9 th July, 2025
Report Updated	

Report History

Name	Company	Email	Description
Bhavik Limbachiya	Blueinfy	blimbachiya@kpmg.com	Creator
Jitendra Patel	Blueinfy	jitendrapatel1@kpmg.com	Reviewer

Table of Contents

1.	Executive Summary.....	4
2.	Overview	7
3.	Vulnerability Details.....	8
3.1.	Identified Vulnerabilities during PTI 900295	8
3.2.	Informational/Notes Items	30
4.	Appendix	40
4.1.	Appendix A - Application Risk Score Matrix	40
4.2.	Appendix B - 5 STAR Assessment Rating System.....	42
4.3.	Appendix C - Terminology	43
4.4.	Appendix D - Methodology for Application Assessment.....	44
4.5.	DSG Disclaimer Notice.....	45

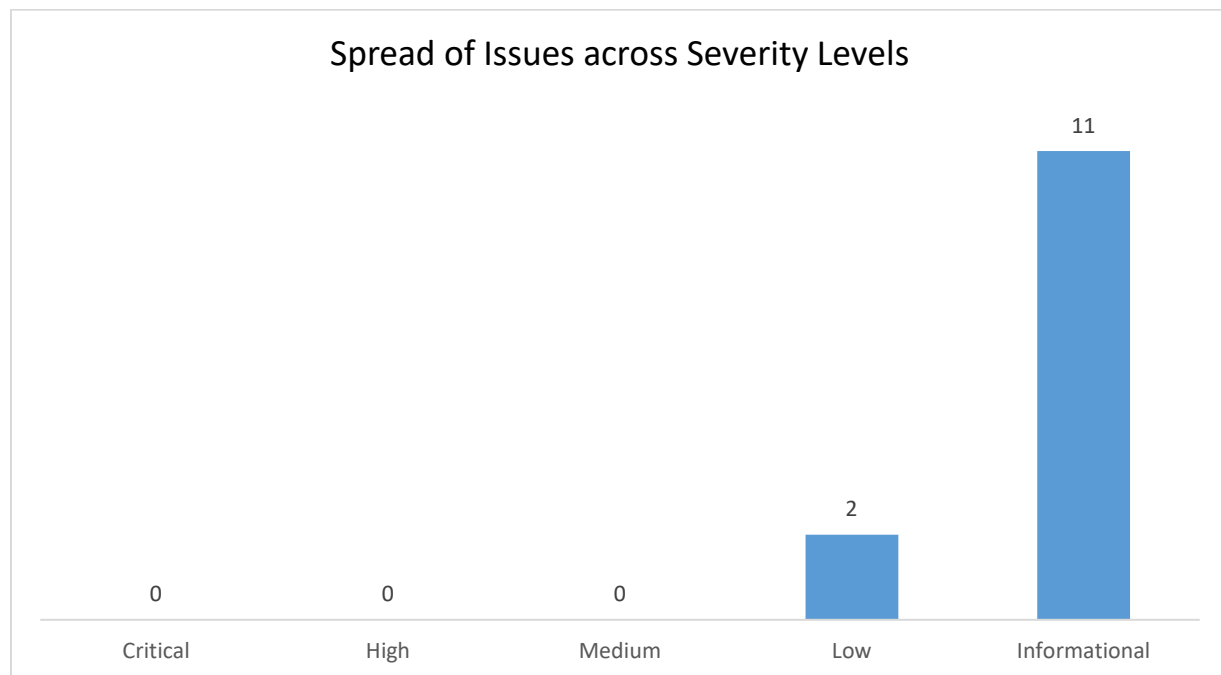
1. Executive Summary

As part of Digital Security Group's (DSG) Software Security and Penetration Testing Program, Blueinfy has conducted vulnerability assessment and configuration check on the SSO implementation for the Report and Retain application.

The Blueinfy team performed time bound security testing through manual methods. Blueinfy has leveraged Burp Suite for conducting the manual test along with other open source security testing software's.

The purpose of this SSO configuration check on the application was to identify the potential vulnerabilities. The manual assessment encompassed the modules of Information gathering, Configuration management, Authentication testing, Authorization testing, session management, Input validation, and encryption to identify the security issues which could potentially affect the application.

Blueinfy Security team has identified a total of 13 vulnerabilities (which includes manual assessment) with multiple instances categorized under varied severity levels. No automated scans were performed for this SSO configuration check. The graph provides a snapshot of the number of issues across Severity Levels.



Vulnerabilities and findings are divided based on their impact (potential damage) and likelihood (probability of identification and exploit). High impact / high likelihood vulnerabilities represent the highest priority and present the greatest threat. Low impact / low likelihood vulnerabilities are the lowest priority and present the smallest threat. See Appendix C for more information.

The list of identified vulnerabilities that are open as of 07/09/2025 has been provided below:

#	Vulnerability	Risk Rating	Dependency	Updated Risk Rating	From Previous Pen Test?
1	SAML Timeout too Long	Low	Application		Jun 2025
2	Application does not Redirect upon Session Expiration	Low	Application		Jun 2025
3	Weak Content Security Policy (Improper CSP header leads to XSS)	Low	Okta	Informational	Jun 2025
4	Misconfigured/Insecure Response Header	Low	Okta	Informational	Jun 2025
5	Sensitive Information displayed in URL	Low	Okta	Informational	Jun 2025
6	SAML - Weak Canonicalization Method Used	Low	Okta	Informational	Jun 2025
7	Session Fixation	Low	Okta	Informational	Jun 2025
8	KPMG Network Credentials sent to Vendor Hosted System (Over the Internet)	Low	Okta	Informational	Jun 2025
9	Expired Token Accepted	Low	Okta	Informational	Jun 2025
10	Webserver Version Revealed	Informational	Okta		Jun 2025
11	Concurrent User Session	Informational	Okta		Jun 2025
12	CBC-mode Encryption in TLS (Lucky 13 attack)	Informational	Okta		Jun 2025
13	Webserver Metafiles for Information Leakage	Informational	Okta		Jun 2025

The additional details pertaining to the vulnerability assessment & penetration testing of the application is provided below.

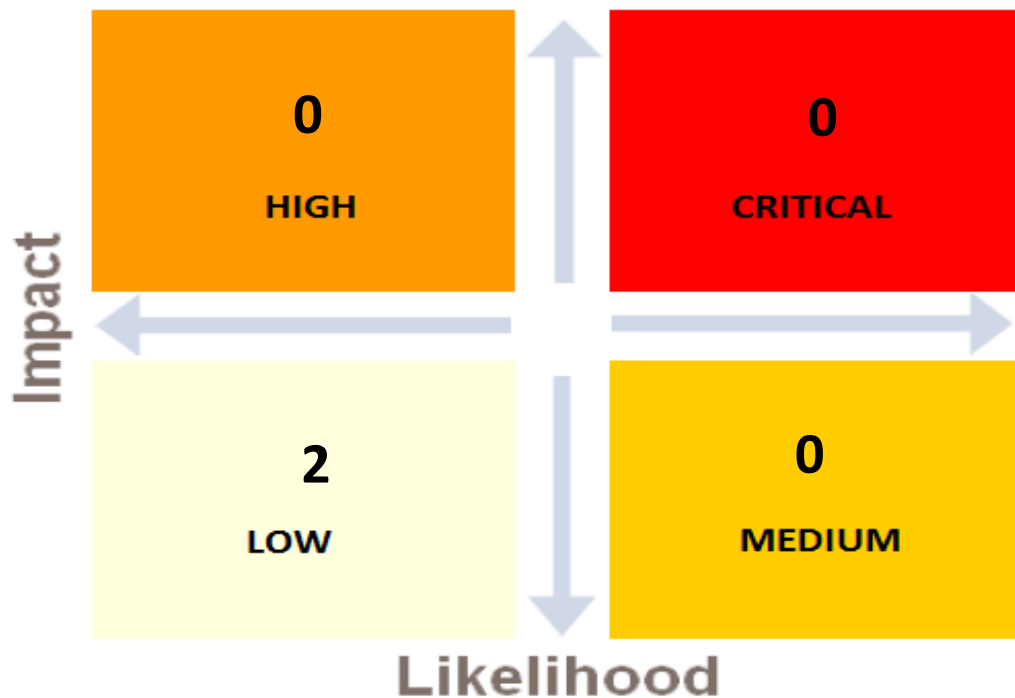
Test URL	https://rr.qa.us.kworld.kpmg.com/UI/ https://damproxy.qa.us.kworld.kpmg.com/ https://kpmgstaging.oktapreview.com/ https://kpmgstaging.kerberos.oktapreview.com/
Testing Environment	Non-Production
Number of Access Level in Scope	10
User Roles	1. Super Admin + Workspace Admin (DRMS), 2. Docket Partner, 3. Docket Manager, 4. Docket EQCR, 5. L1 Reviewer, 6. L2 Reviewer, 7. Docket Delegates, 8. Form AP Delegates, 9. NDPPS Admin, 10. XML Reviewer
Scope of Test	Limited
Testing Window	N/A
Point of Contact (App Team)	Soroko, Monika

Disclaimer: *This report contains examples of instances where certain vulnerabilities have been identified. However, the issue may not be only limited to the instances reported. We certainly advise that a global fix be implemented to remediate all vulnerabilities and not limit the remediation to just the instances identified in this report.*

2. Overview

The table below provides an overview of the SSO configuration check conducted on the Report and Retain application.

Project/Application	Report and Retain
Type of Testing	Pre-Production SSO Configuration Check
Assessment Date	7th July, 2025
Type of Assessment	Dynamic Manual Assessment
Tools Used	Burp Suite & other Open Source Tools
Total Number of Issues	13 (2 Low and 11 Informational)
STAR Rating	4 Star★★★★

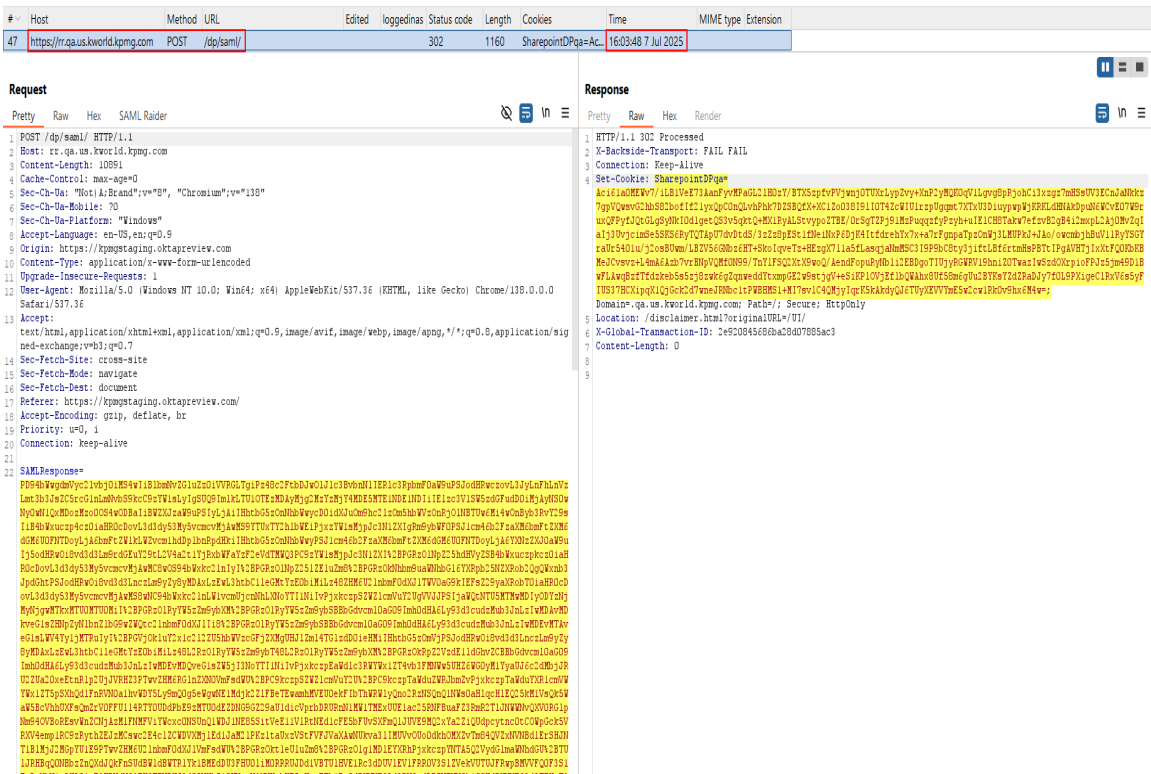


Additionally, 11 Informational issues have been reported as part of the testing activity.

3. Vulnerability Details

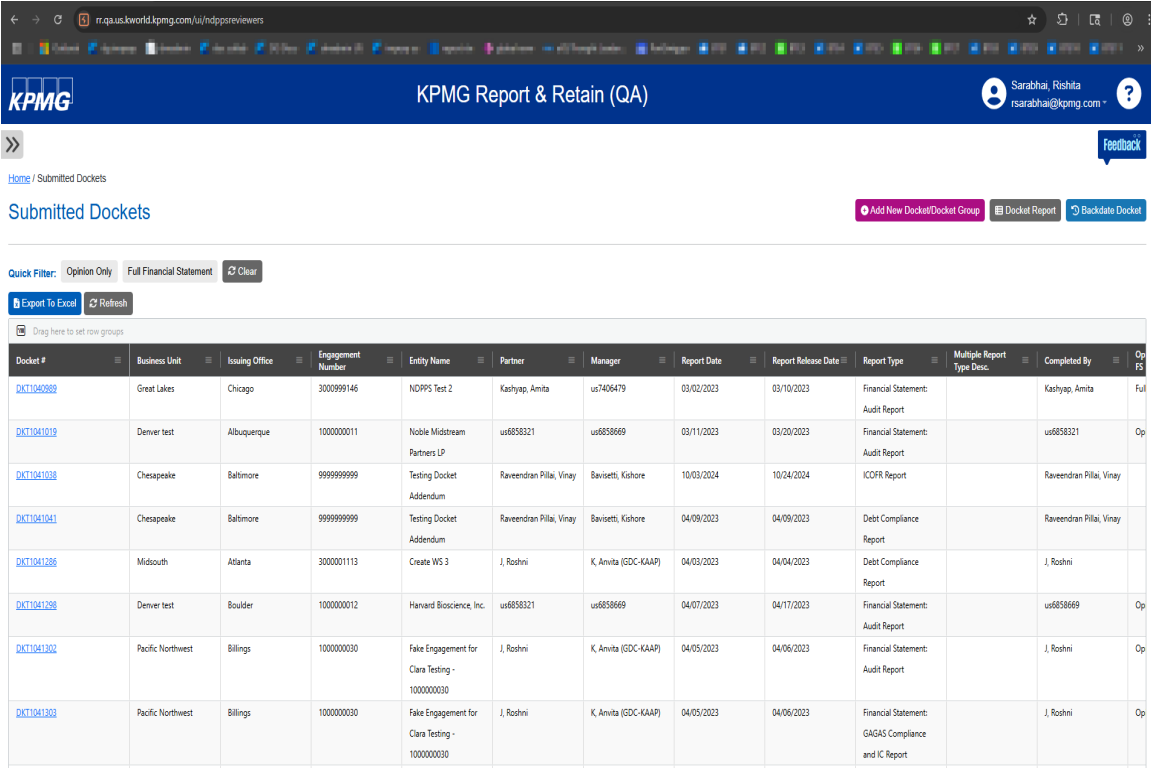
3.1. Identified Vulnerabilities during PTI 900295

This section contains vulnerabilities that are identified during the **pre-production** test. This SSO configuration check was conducted during **07/07/2025** and **07/09/2025**.

Vulnerability	1. SAML Timeout too Long	Status	Open
Risk Rating	Low	Vulnerability Owner	Application
Issue Description:	SAML messages should contain a timestamp of when the request was issued, when it expires or both. If the SAML message never expires or if the expiration is not honored, there is a greater risk of a message falling into the hands of an attacker and the SAML being replayed to log in to the application without use of credentials.		
URL	https://rr.qa.us.kworld.kpmg.com/dp/saml/		
Screenshots:			
			

KPMG Confidential 9 | Page

(Closing/Down grading) Justification	
---	--

Vulnerability	2. Application does not Redirect upon Session Expiration		Status	Open
Risk Rating	Low	Vulnerability Owner	Application	
Issue Description:	After the user's session ends from a period of inactivity, the page does not redirect to the logout screen or the login page. Anyone who has access to the computer can view the contents of the page contents of the page which will be a risk if it has sensitive information.			
URL	https://rr.qa.us.kworld.kpmg.com/ui/ndppsreviewers			
Screenshots: 				
Remediation	Redirect user to logout screen after session times out.			
(Closing/Down grading) Justification				

Vulnerability	3. Weak Content Security Policy (Improper CSP header leads to XSS)		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The Content Security Policy header allows you to define a whitelist of approved sources of content for your site. By restricting the assets that a browser can load for your site, like js and css, CSP can act as an effective countermeasure to XSS attacks. The configured CSP uses unsafe attributes like unsafe-inline and unsafe-eval and certain directives.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDssso/interact?precheck=false&interactionHandle=eDlzd0ZhTU9XQWo2d3RWa05uQXZvSmZ6K05qYWJubjg5QXJxUnRSbEJkMGw5eEo3eTF0VkFaMUdra0xXajNvTA			
<u>Instance 1: (Informational)</u> <u>Screenshots:</u>				

143 https://kpmgstaging.oktapreview.com /app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=A... GET 200 ✓ 16693 HTML 75.2.32.98

Request Response

Pretty Raw Hex Render

'self' kpmgstaging.oktapreview.com data: *.oktacdn.com fonts.gstatic.com; frame-ancestors 'self'

11 **Content-Security-Policy:** default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oimmanager.okta.com data: *.ingest.sentry.io data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com; script-src 'unsafe-inline' 'nonce-OIzk9nnu4myQTxhofYlKbQ' 'unsafe-eval' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; frame-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com login.okta.com *.vidyard.com com-okta-authenticator;; img-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com *.tiles.mapbox.com *.mapbox.com *.vidyard.com data: data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com blob;; font-src 'self' kpmgstaging.oktapreview.com data: *.oktacdn.com fonts.gstatic.com; frame-ancestors 'self'

12 X-Rate-Limit-Limit: 40

13 X-Rate-Limit-Remaining: 39

14 X-Rate-Limit-Reset: 1751872840

15 Set-Cookie: JSESSIONID=AR8D982FBB4F4BDF7DA05D65C55B6361; Path=/; Secure; HttpOnly

Content-Security-Policy

2 matches

Content Security Policy

[Sample unsafe policy](#) [Sample safe policy](#)

```
kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com
kpmgstaging.kerberos.oktapreview.com kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769
http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111
http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121
*.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131
*.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141
*.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oimmanager.okta.com
data: *.ingest.sentry.io data.pendo.io pendo-static-5634101834153984.storage.googleapis.com
pendo-static-5391521872216064.storage.googleapis.com; script-src 'unsafe-inline' 'nonce-OIzk9nnu4myQTxhofYlKbQ'
'unsafe-eval' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline'
'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; frame-src 'self' kpmgstaging.oktapreview.com
kpmgstaging-admin.oktapreview.com login.okta.com *.vidyard.com com-okta-authenticator;; img-src 'self'
kpmgstaging.oktapreview.com *.oktacdn.com *.tiles.mapbox.com *.mapbox.com *.vidyard.com data: data.pendo.io
pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com
blob;; font-src 'self' kpmgstaging.oktapreview.com data: *.oktacdn.com fonts.gstatic.com; frame-ancestors
```

CSP Version 3 (nonce based + backward compatibility checks) ⓘ

CHECK CSP

Evaluated CSP as seen by a browser supporting CSP Version 3 [expand/collapse all](#)

✓ default-src

ⓘ connect-src

ⓘ script-src

Host allowlists can frequently be bypassed. Consider using 'strict-dynamic' in combination with CSP nonces or hashes.

✓ style-src

✓ frame-src

✓ img-src

✓ font-src

✓ frame-ancestors

ⓘ base-uri [missing]

Missing base-uri allows the injection of base tags. They can be used to set the base URL for all relative (script) URLs to an attacker controlled domain. Can you set it to 'none' or 'self'?

ⓘ require-trusted-types-for [missing]

Consider requiring Trusted Types for scripts to lock down DOM XSS injection sinks. You can do this by adding "require-trusted-types-for 'script'" to your policy.

Instance 2: (Informational)

Screenshots:

13 | Page

KPMG Confidential

120 https://kpmgstaging.kerberos.oktapreview.com /login/agentlessDso/interact?precheck=false&interactionHandle=eDz0ZhtU9XQWo... GET 200 ✓ 22246 HTML 752.32.98

Request Response

Pretty Raw Hex Render

```

kpmgstaging.oktapreview.com data: *.oktacdn.com fonts.gstatic.com; frame-ancestors 'self' https://always-on-stg.wisewindow.com
12 Content-Security-Policy: default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com
kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mtls.oktapreview.com
*.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111
http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131
http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141
*.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oinmanager.okta.com data: *.ingest.sentry.io; script-src
'unsafe-inline' 'nonce-y3ZUoaQVv7lJuRpPw7w5w' 'unsafe-eval' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src
'unsafe-inline' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; frame-src 'self' kpmgstaging.oktapreview.com
kpmgstaging-admin.oktapreview.com login.okta.com *.vidyard.com com-okta-authenticator;; img-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com
*.tiles.mapbox.com *.mapbox.com *.vidyard.com data: blob;; font-src 'self' kpmgstaging.oktapreview.com data: *.oktacdn.com fonts.gstatic.com;
frame-ancestors 'self' https://always-on-stg.wisewindow.com
13 X-Rate-Limit-Limit: 600
14 X-Rate-Limit-Remaining: 594
15 X-Rate-Limit-Reset: 1751872836
16 Referrer-Policy: strict-origin-when-cross-origin
17 Cache-Control: no-cache, no-store
18 Pragma: no-cache

```

Content-Security-Policy 2 matches

Content Security Policy

Sample unsafe policy Sample safe policy

```

default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com
kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com
kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769
*.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111
*.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121
*.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131
*.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141
*.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oinmanager.okta.com
data: *.ingest.sentry.io; script-src 'unsafe-inline' 'nonce-y3ZUoaQVv7lJuRpPw7w5w' 'unsafe-eval' 'self'
'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline' 'self' 'report-sample'
kpmgstaging.oktapreview.com *.oktacdn.com; frame-src 'self' kpmgstaging.oktapreview.com
kpmgstaging-admin.oktapreview.com login.okta.com *.vidyard.com com-okta-authenticator;; img-src 'self'
kpmgstaging.oktapreview.com *.oktacdn.com *.tiles.mapbox.com *.mapbox.com *.vidyard.com data: blob;; font-src
'self' kpmgstaging.oktapreview.com data: *.oktacdn.com fonts.gstatic.com; frame-ancestors 'self'
https://always-on-stg.wisewindow.com

```

CSP Version 3 (nonce based + backward compatibility checks)

CHECK CSP

Evaluated CSP as seen by a browser supporting CSP Version 3

expand/collapse all

- ✓ default-src
- ✗ connect-src
- ✗ script-src
- ✓ style-src
- ✓ frame-src
- ✓ img-src
- ✓ font-src
- ✓ frame-ancestors
- ✗ base-uri [missing]
- ✗ require-trusted-types-for [missing]

Host allowlists can frequently be bypassed. Consider using "strict-dynamic" in combination with CSP nonces or hashes.

Missing base-uri allows the injection of base tags. They can be used to set the base URL for all relative (script) URLs to an attacker controlled domain. Can you set it to "none" or "self"?

Consider requiring Trusted Types for scripts to lock down DOM XSS injection sinks. You can do this by adding "require-trusted-types-for 'script'" to your policy.

Remediation

Basic CSP policy should be implemented. This policy will only allow resources from the originating domain for all the default level directives and will not allow inline scripts/styles to execute. If your application functions with these

	restrictions, it drastically reduces your attack surface and will work with most modern browsers. For configuring the CSP, please refer to the below links: - https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP https://csp-evaluator.withgoogle.com/
(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.

Vulnerability	4. Misconfigured/Insecure Response Header		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The application sets the security response header (X-XSS-Protection) with an incorrect mode. The security response headers should be implemented properly with correct values.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED <u>Instance 2:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED			

Instance 1: (Informational)

Screenshots:

143 https://kpmgstaging.oktapreview.com /app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=A... GET 200 ✓ 16693 HTML 75.232.98

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Mon, 07 Jul 2025 07:20:30 GMT
3 Content-Type: text/html; charset=utf-8
4 Server: nginx
5 Vary: Accept-Encoding
6 X-Okta-Request-Id: 3151ed3519d46ed8d88a1fb33c105944
7 Accept-Ch: Sec-CH-UA-Platform-Version
8 X-Xss-Protection: 0
9 CSP: CP="HONK"
10 Content-Security-Policy-Report-Only: default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oinmanager.okta.com data: *.ingest.sentry.io data.pendo.io pendo-static-5634101834153984.storage.googleapis.com pendo-static-5391521872216064.storage.googleapis.com; script-src 'unsafe-inline' 'nonce-OI2k9nnu4myQTxhofYlK8Q' 'unsafe-eval' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline' 'nonce-OI2k9nnu4myQTxhofYlK8Q' 'self' 'report-sample'
```

X-Xss-Protection 1 match

Instance 2: (Informational)

Screenshots:

120 https://kpmgstaging.kerberos.oktapreview.com /login/agentlessDssso/interact?precheck=false&interactionHandle=eDlzd0ZlTU9XQWo... GET 200 ✓ 22246 HTML 7523298

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Mon, 07 Jul 2025 07:20:26 GMT
3 Content-Type: text/html; charset=utf-8
4 Server: nginx
5 Vary: Accept-Encoding
6 X-Okta-Request-Id: 0e8648b38e10b695f6a405400bd848e2
7 Accept-Ch: Sec-CH-UA-Platform-Version
8 X-Xss-Protection: 0
9 CSP: CP="HUNK"
10 Set-Cookie: xids="";Version=1;Path=/;Max-Age=0
11 Content-Security-Policy-Report-Only: default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oimanager.okta.com data: *.ingest.sentry.io; script-src 'unsafe-inline' 'nonce-y3ZUoaQVv7lJuRPPFW7w5w' 'unsafe-eval' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline' 'nonce-v3ZUoaQVv7lJuRPPFW7w5w' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com;
```

X-Xss-Protection 1 match

Remediation	Set the value of the response header to X-XSS-Protection: 1; mode=block.
--------------------	--

(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.
---	--

Vulnerability	5. Sensitive Information displayed in URL		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The application sends sensitive information as a variable within the URL as a query string parameter. Information sent in the URL query string is logged in several places, such as the client browser, intermediate proxy servers and web server logs and is susceptible to shoulder surfing attacks.			
URL	https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_			
Screenshots: 339https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_GET200✓40194HTML99.83.191.34KPI RequestResponse PrettyRawHex 1GET /login/token/redirect?stateToken=02.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2 HTTP/2 2Host: kpmgstaging.oktapreview.com 3Cookie: DT=DI14w6RXeNRsdWGzYUuIo7yzg; JSESSIONID=72D4918ADB4899F507CD0EBF78867AEF 4Sec-Ch-Ua: "Not:A-Brand";v="24", "Chromium";v="134" 5Sec-Ch-Ua-Mobile: ?0 6Sec-Ch-Ua-Platform: "Windows" 7Sec-Ch-Ua-Platform-Version: "" 8Accept-Language: en-US,en;q=0.9 9Upgrade-Insecure-Requests: 1 10User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36 11Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 12Sec-Fetch-Site: same-origin 13Sec-Fetch-Mode: navigate 14Sec-Fetch-Dest: document 15Referer: https://kpmgstaging.oktapreview.com/login/agentlessDsoo/auth 16Accept-Encoding: gzip, deflate, br 17Priority: u=0, i 18				
Remediation	Send all sensitive information as parameters via POST request.			
(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.			

Vulnerability	6. SAML - Weak Canonicalization Method Used		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	In order, that logically-identical XML documents give identical digital signatures, an XML canonicalization transform is employed when signing XML documents. These algorithms guarantee that semantically-identical documents produce exactly identical serialized representations. In this scenario, it is observed that the xml-exc-c14n# method is used, which is known to have possible xml injection vulnerabilities as this algorithm does not take into consideration the comments within the XML. Details on SAML XML Injection can be found here: https://research.nccgroup.com/2021/03/29/saml-xml-injection/			
URL	https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_			
Screenshots: 339https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_GET20040194HTML99.83.191.34KPI RequestResponse PrettyRawHexRender 176</script><form id="appForm" action="https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_.id.Zzs-2XG2gc0CgSwCUxabRXSe_4P-8jSjXxgBMh2_" method="POST"><input name="SAMLResponse" type="hidden" value="PD94bWwgdmVyc2l0b3Jvbm90bWw1QWwzODNDODU1MjI1LjE1L				

(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.
---	--

Vulnerability	7. Session Fixation		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	In a session fixation attack, the user is tricked into using a session identifier chosen by the attacker before the user even logs into the web application on the target server. i.e. the user’s session identifier has been fixed in advance by the attacker instead of being generated randomly at login. HTTP is a stateless protocol, which means that it does not maintain state throughout a user’s subsequent requests. Web servers/web applications implement session management to maintain session data and achieve statefulness. The server generates a session identifier and sends this identifier to the client (user’s browser). The client identifies itself by sending this unique identifier with each subsequent request. To perform a session fixation attack the attacker uses any one of the transport mechanisms – URL arguments, hidden form fields and cookies to maintain sessions in a web environment.			
URL	https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.7EW5QonG1Ng0cZcx8umY1FLmXiLxXchxNfyiv4GE			
<u>Reproduction Steps:</u>				
1. Open the URL "https://kpmgstaging.oktapreview.com/" 2. Observe the response 3. The application sets "stateToken" in the response before login 4. Log in to the application 5. Intercept the request using a proxy tool 6. Copy the target URL (URL with "stateToken") 7. Drop the request 8. Open the copied URL in an unauthenticated browser 9. This will allow to log in to the application using "stateToken" which is set before login				
<u>Screenshots:</u>				

322 https://kpmgstaging.oktapreview.com /login/agentlessDso/auth POST 200 ✓ 23500 HTML 99.83.191.34 KPI

Request Response

Pretty Raw Hex Render

```
    }  
    };  
  }  
</script>  
<script type="text/javascript" nonce="jC1Q4wFnyC48-bRCXRnX-A">  
252   (function() {  
253     var baseUrl = 'https://kpmgstaging.oktapreview.com';  
254     var suppliedRedirectUri = '';  
255     var repost = false;  
256     var stateToken = '02.id.Zzs\X2D2XG2gc0CgSwCUxabRXSe_4P\X2D8jsjXxgBMh2_';  
257     var fromUri = 'X2Fapp\X2tkpmgstaging_reportretainadmlnportalqa_2\X2Fexkkub4qma2clvyW8ld7\X2Fsso\X2Fsaml';  
258     var username = '';  
259     var rememberMe = true;  
260     var smsRecovery = true;  
261     var callRecovery = true;  
262     var emailRecovery = true;  
263     var usernameLabel = 'Username';  
264     var usernameInlineLabel = '';
```

02.id.Zzs\X2D2XG2gc0CgSwCUxabRXSe_4P\X2D8jsjXxgBMh2_ X 1 match

Intercept on Forward Drop Request to https://kpmgstaging.oktapreview.com:443 [99.83.191.34]

Time	Type	Direction	Method	URL
13:44:15.7	HTTP	Request	GET	https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.7EW5QonG1Ng0cZcx8umY1FLmXlXchNfyiv4GE

Request

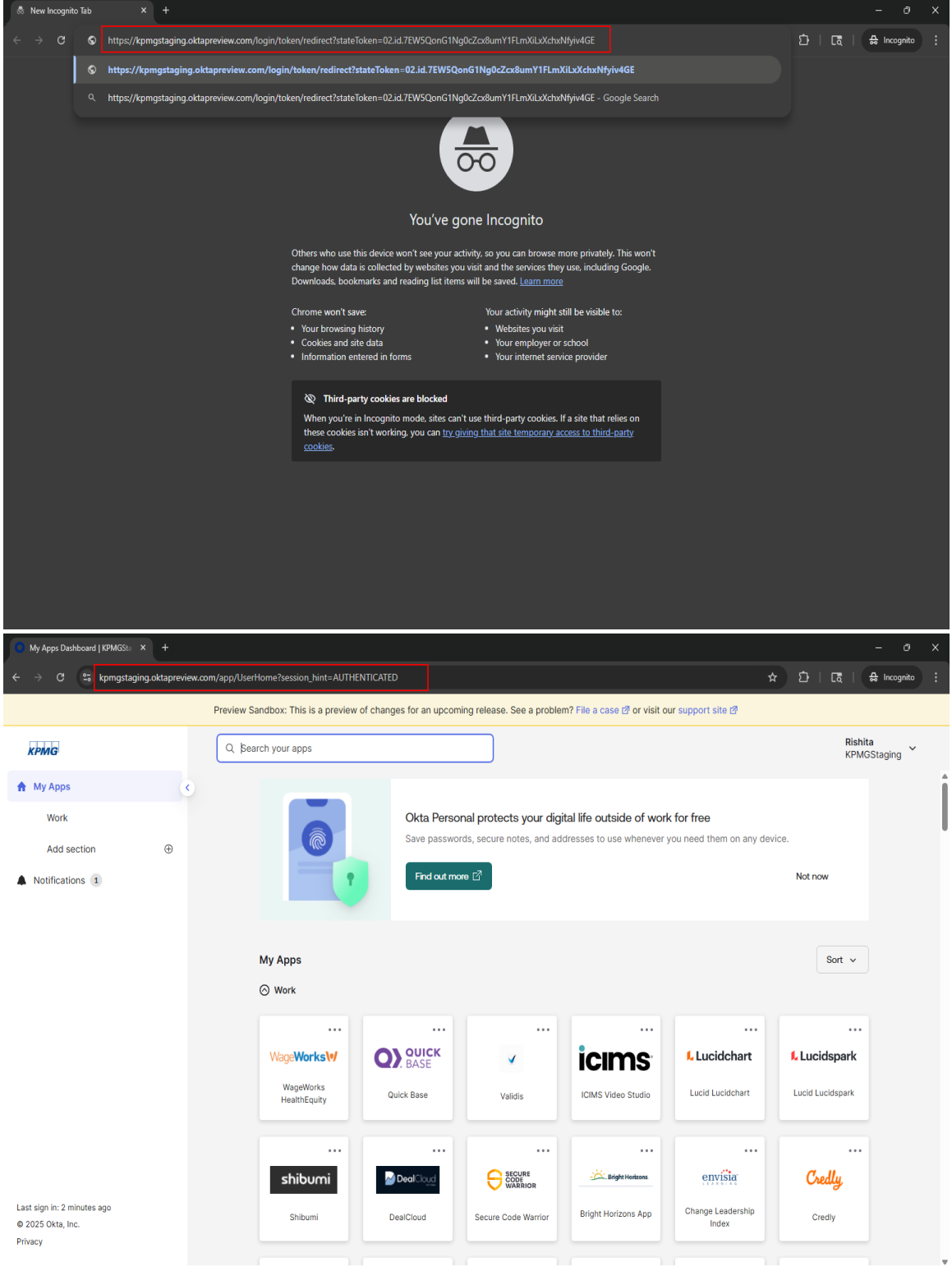
Pretty Raw Hex

```
1 GET /login/token/redirect?stateToken=02.id.7EW5QonG1Ng0cZcx8umY1FLmXlXchNfyiv4GE HTTP/2  
2 Host: kpmgstaging.oktapreview.com  
3 Cookie: DT=D114rg4JBocSyq-aqQAnCr7CQ; okta_user_lang=en; ln=rsarabhai@kpmg.com; JSESSIONID=AF73A11BD2D1F799584c291750AAAF  
4 Sec-Ch-Ua: "Not:A-Brand";v="24", "Chromium";v="134"  
5 Sec-Ch-Ua-Mobile: ?0  
6 Sec-Ch-Ua-Platform: "Windows"  
7 Sec-Ch-Ua-Platform-Version: ""  
8 Accept-Language: en-US,en;q=0.9  
9 Upgrade-Insecure-Requests: 1  
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36  
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7  
12 Sec-Fetch-Site: same-origin  
13 Sec-Fetch-Mode: navigate  
14 Sec-Fetch-Dest: document  
15 Referer: https://kpmgstaging.oktapreview.com/login/agentlessDso/idx?stateToken=RVVh2GMxYU1nM1BRN0d2bXFNQXFSaEJXQ2NudWpxTFpRTzMrch2VKnLOXRnOq&precheckFailure=true&redirectFromAdso=true  
16 Accept-Encoding: gzip, deflate, br  
17 Priority: u=0, i  
18  
19
```

Event log (3) All issues (124)

Inspector Notes

- Scan
- Do passive scan
- Do active scan
- Send to Intruder Ctrl+I
- Send to Repeater Ctrl+R
- Send to Sequencer
- Send to Comparer
- Send to Decoder
- Send to Organizer Ctrl+O
- Insert Collaborator payload
- Request in browser
- Engagement tools
- Change request method
- Change body encoding
- Copy Ctrl+C
- Copy URL
- Copy as curl command (bash)
- Copy to file
- Paste from file
- Save item
- Don't intercept requests
- Do intercept
- Convert selection
- URL-encode as you type
- Cut Ctrl+X
- Copy Ctrl+C
- Paste Ctrl+V
- Message editor documentation
- Proxy interception documentation

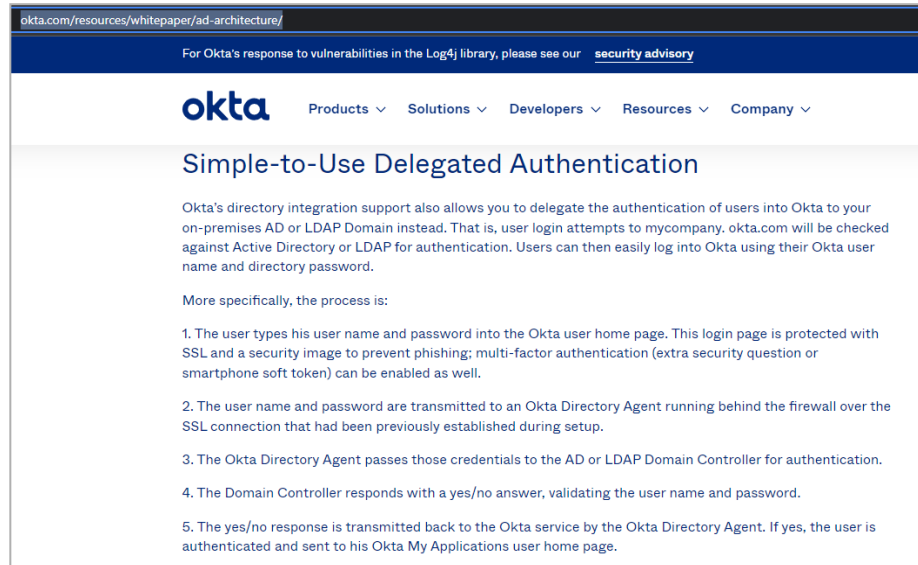


The screenshot displays a web browser window with two tabs. The first tab is titled "New Incognito Tab" and shows a URL: `https://kpmgstaging.oktapreview.com/login/token/redirect?stateToken=02.id.7EWSQonG1Ng0cZcx8umY1FLmXlXchoNfyiv4GE`. The second tab is titled "My Apps Dashboard | KPMGSTaging" and shows a URL: `kpmgstaging.oktapreview.com/app/UserHome?session_hint=AUTHENTICATED`. The dashboard page features a search bar, a sidebar with "My Apps", "Work", "Add section", and "Notifications" (1), and a main content area with a "My Apps" section. The "My Apps" section lists various applications including WageWorks, Quick Base, Validis, ICIMS Video Studio, Lucidchart, Lucidspark, Shibumi, DealCloud, Secure Code Warrior, Bright Horizons App, Change Leadership Index, and Credly. A "Remediation" section is visible at the bottom of the dashboard, containing the text: "Invalidate the old session identifier and issue a new one. Use a nonce token to identify sessions. Generate a secret token when a user logs in to the".

Remediation	
	Invalidate the old session identifier and issue a new one. Use a nonce token to identify sessions. Generate a secret token when a user logs in to the

	application, keep the token at the server and include this token in every link and sensitive form. Ensure that the token generated is sufficiently random.
(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.

Vulnerability	8. KPMG Network Credentials sent to Vendor Hosted System (Over the Internet)		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	There are two authentication mechanisms for this implementation – one of the two (form-based authentication) sends KPMG network credentials over the internet to a third party owned network (Okta). Application pen testing team interviewed Okta technical consultant in presences of Security architect team and KPMG Okta solution engineering team. Okta consultant confirmed that Okta has the technical ability to read KPMG passwords in cleartext in many cases such as and not limited to SSL offloading and memory dumps. However, they provided the following mitigation controls that Okta believes it will mitigate the risk. [EXTERNAL] KPMG: WageWorks Pen Test Results - Password Protections Follow-up  Susie Godfrey <susie.godfrey@okta.com> To: Manda, Lokesh Babu; Schellenberg, Greg; Dugan, Michael; Jacob, Vinu; Polonetsky, Steve; Maher, Patrick; Wassef, Sam Click here to download pictures. To help protect your privacy, Outlook prevented automatic download of some pictures in this message. Wed 1/12/2022 8:34 AM Hi Team, Good morning! Please find Okta's response below regarding your questions during our meeting yesterday about password security controls. Okta has in place controls to protect the security of passwords submitted into the Service. This currently includes, but is not limited to: - Secure code training to reduce the likelihood of capturing passwords in logs - Monitoring of logs to detect misconfigurations that may capture customer passwords - Limitation of access to systems (such as networking, infrastructure, and applications that would enable an employee to view or intercept customer passwords that traverse the service) to only those individuals with a business need - Monitoring of employee use of privileged commands, such as infrastructure changes, memory dumps, or process access, that would allow an employee to view or intercept customer passwords - A separate Defensive Cyber Operations team as part of Okta's Security team to investigate and respond to alerts Please reach out if there is any additional information I can provide to assist with your review. -- Susie Godfrey Sr. Customer Success Manager 734-233-4087			
The mentioned controls are out-side the scope of application pen-testing. On the other hand, the pen-testing team refers to the published architecture on Okta website https://www.okta.com/resources/whitepaper/ad-architecture/				



As per the above screen shot, Okta confirms that the username and password are transmitted over SSL, but it does not mention the SSL termination point. Okta consultant clarified that there is SSL offloading occurs before the server farm.

In addition, the above written response from Okta didn't mention the SSL connection is established between the browser and the directory agent as mitigation control.

Next, the pen-testing team refers to KPMG's password security standards document. The standard states firmly that KPMG passwords must be kept secret from those who do not own it.

3 Security Standard - Passwords

3.1 Preface

A password is a sequence of characters that is used for authentication, to prove identity or gain access to a resource (example: an access code is a type of password). The password must not be shared and must be kept secret from those who do not own the password. Access to assets (including devices, systems, networks and information) is based on business requirements, information classification and information security risks. Password mechanisms are an established approach to prove identity (authentication) to gain access to a resource.

These requirements support the *KPMG Global Information Security Policies* as per the referenced mappings to ISO controls and associated KPMG policy statements.

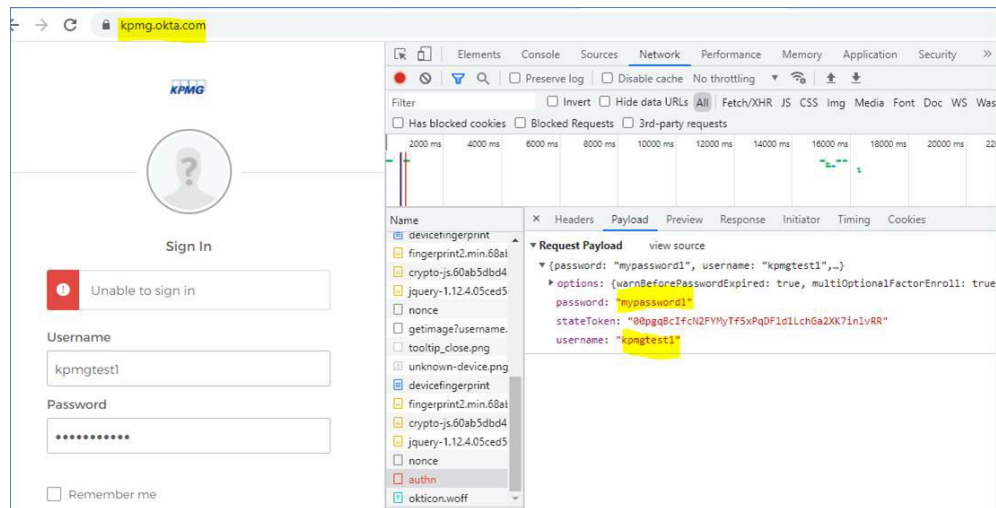
Additional security standards reference

<https://cwe.mitre.org/data/definitions/319.html>

<https://cwe.mitre.org/data/definitions/312.html>

<https://cwe.mitre.org/data/definitions/256.html>

It is extremely important to note the vulnerability exists in production “kpmg.okta.com”



Accordingly, the risk from application security perspective is high.

URL

<https://kpmgstaging.oktapreview.com/idp/idx/challenge/answer>

Screenshots:

405 https://kpmgstaging.oktapreview.com /idp/idx/challenge/answer POST 200 ✓ 6678 JSON 99.83.191.34

Request	Response
20 Accept-Encoding: gzip, deflate, br 21 Priority: u=1, i 22 23 { "credentials": { "passcode": "KPMG1234567890" } "stateHandle": "02.id.CE08P3jBIN30gK29aD89Q_jl7DkM5MrUuWkZ5e0d~c.UvsQixeoq8I1RjNg48q6pvBACSDIWD2Q2oPqGtMkBXQ5YwpialHMxPC6btMePtb_i_z33PM4IgOmFheRsoUCrMRO4h6V7xJ7Kzy44ifjb-a5f8GdvY843QzwOasOI2hd8QANULR2wp6N7-X77qfMT9vYPr6BXopAuhIqB8imtqfQOMG9JsOItrAPjvCF8MfC2ZMISxXcJQjaN50NlshdBLEVpzez-X7zUwlyKSQ14oLWKUDgRo6Tf2xM1VXPxn76rp_69Fle5J26tQkVD6TAP7Jf2nxd1JK46709nLpLc5s-sdK-yR46bqIxogrjY6HqJLc3PwVrP0vHk3RqCk_hOdUHTn4y8WFFtt2LSMIEk7HelAy2p2fAL-dL1LoTOYdgg8mpBe1ndTmc1czItDpmpuHTT019jsUipfT9i1pyl7vnaHWW6RSQjv_LGvsfbWRau-9X3WZY_3ZzGM--gDktYSAcqaNG53G8zDHWshuRda0C_Hk4g75rMuVX71nVOchCxKoidpCgB7yMdVLA0NLJXPYUx8onVjsLdtzBrb2MiskvBuVbQaYBuIfE76djtbsWYfors_oVgmffjTMOX8ANHI0yUAWcwl782HdMQ3cf9IsCCjPewd9reZa17yYpICfB6gtgl0Uo5lm4erE3y_5rVVBpbw3Im-7VochiavN6LGeQtv5FsGs5dZtp2xMyaeYKJCRH3AP-DkiPkB1ksYiB9aK4B_z9ouktrUPhorbJTG15sLGZPrHCsQ2DR8kWhUC3dmGWDPSYkn_8iI32Nesph_fPk0aELsvPU526Z-iBqumd9FB6CLswTov_xN3-X21_xVw7ABQuG53xarUHRtVArMp2dIRSNsY09xaC6kksbJPxgVDEZfSt1BaJWHpJsmxQ9QGRUpr_UVnNL_5N7efpCzb7XowxWampsjGtBdHYfGMKAJUcm2krjkqgrjsY7v3EY9wmagz5TgIhVv_ToUeWaytzhh0sBjddL9URL0JdezWkN-_gmImuw4YHnjhFA5HLAwoLoKwb1WMNd517DqUCVIMAmVvOhPTCn15F2c9H124kHBNksvM34QeN2-JytZcpE5ahM1ErD0pk17gV469URS-uZUupD2rhuQH5Bu6jxfBN20Eonq5eh7m-gZdmrcTJRQczWtg4D64yTo-0vSDPLqMHRs8Asx9tfB2mtWhwTag44ABjCxd"	

Remediation

KPMG network credentials must be kept secret during rest and in motion till it reach the directory agent

(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.
---	--

Vulnerability	9. Expired Token Accepted		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The application lets the user log in with a token from the Okta Verify application which has already expired.			
URL	https://kpmgstaging.oktapreview.com			
<u>Reproduction Steps:</u> 1. There is an option to use Okta Verify as MFA to log in to the Okta Dashboard 2. The token generated in the application is usable for 5 minutes even after expiration				
Remediation	Old token should be invalidated from the server side once a new token is generated.			
(Closing/Down grading) Justification	07/09/2025: - The risk rating of this finding was downgraded to informational, as this finding belongs to a platform with PPA 406141, and all the corresponding risks are tracked under RP 406144.			

3.2. Informational/Notes Items

Vulnerability	10. Webserver Version Revealed		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	The application displays webserver version. This allows an attacker to determine known vulnerabilities and the appropriate exploits to use.			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com/login/agentlessDssso/auth <u>Instance 2:</u> https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED <u>Instance 3:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDssso/interact?precheck=false&interactionHandle=eDlzd0ZhTU9XQWo2d3RWa05uQXZvSmZ6K05qYWJubjg5QXJxUnRSbEJkMGw5eEo3eTF0VkJFaMUdra0xXajNvTA <u>Instance 4:</u> https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDssso/interact?precheck=false&interactionHandle=d1ZQT2V5UGxqY2MvSUpuZzlnY1FtdU8vdGgxM3pxRXZPOVJnUTILNzBWZzFtQW0rN2ZYdXJVcFdIRFdaOXFFag			
<u>Instance 1:</u> (Informational) <u>Screenshots:</u>				

322 https://kpmgstaging.oktapreview.com /login/agentlessDso/auth POST 200 ✓ 23500 HTML 99.83.191.34 KP

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Mon, 07 Jul 2025 07:44:33 GMT
3 Content-Type: text/html; charset=utf-8
4 Server: nginx
5 Vary: Accept-Encoding
6 X-Okta-Request-Id: 0096efafe05cb37b72200708f8e04f00
7 Accept-Ch: Sec-CH-UA-Platform-Version
8 X-Xss-Protection: 0
9 P3p: CP="HONK"
10 Set-Cookie: xids=""; Version=1; Path=/; Max-Age=0
11 Content-Security-Policy: default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com
    kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com
    kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769
    *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121
    http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141
    http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151
    https://oimanager.okta.com data: *.ingest.sentry.io; script-src 'unsafe-inline' 'nonce-jClQ4wFnyC48-bRCXRnX-A' 'unsafe-eval' 'self'
    'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline' 'self' 'report-sample' kpmgstaging.oktapreview.com
```

Server: nginx 1 match

Instance 2: (Informational)

Screenshots:

Send Cancel < > Target: https://kpmgstaging.oktapreview.com HTTP/2

Request

Pretty Raw Hex

```
1 Trace /app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&
  session_hint=AUTHENTICATED HTTP/2
2 Host: kpmgstaging.oktapreview.com
3 Cookie: DT=DI15DerOAKdRmiExGWPf8_7aA; okta_user_lang=en; idx=
  eyJ6aXAiOiJERUYiLCJ2ZXIIOiIiIiwiaWxpYXkiOiJlbmNyeXB0aW9ua2V5Iiwib2lkIj
  oIMDBvMmVtZem4lNGtV2l1VnZ2w2DcILCJlbmMiOiJBMjU2R0NNIiwiaWF0Ijoi2GlyIiw
  eHNpZCI6ImkePBRjYqalZsUVppZUFmcV9laWJzQ1EifQ..tYhv8fw2MRcb2kQ.WyIrc
  138qTfhH5QyMheK-iii_FqpxUINTduXOKQaLrd3cVbmd9L-Vrn3T8IsbDcRTJAgQyJZna1
  k27w-mCoIxsG784UvvZONj4eY3-t_JXmZyP6VndHc3Tvl_rM7oU0AGnJ7ho8qla0icq2j
  E1WXUUIqWwX13K8p1cQzm5B1ohK45yxqgmXQ4-A9pjqlf0qv60UyJeuShz29GTSNVR50
  QEQxymM-ILqfvar2d8I_RkzuVaUwtNMQIDJR-7ou_btWAS-E07GgogcvGqy1PVX_2gloU7
  VnqsXrK_Eh24DkC9g2bRn0ofHI2kBwL-6ImGOKObvvL7jts-CTHj8QrCuwKBjQ1GHjU-P
  2zsho-N7rxQlogMxfvfe2PxxwJqCJ4UF5tTkjkswo0tF0_U1_oewj0dhRDEJhSC3gcAyKB
  YswKPBvrcawCwLw07E0jfgxoC-ozt_Wh70royAhhv21GrpD0X2DuVm9QPK-XXvPp1st4Pwp
  rlskWkk_3f91zq2PxfM42xy-1lwNRMqaM9mOpjzTHcgWk21mSJOiDGOChFlo7c2ph5UVRH
  yT-IsXBgNVmjTO1oKQ2Kq185yE1hUH_opeV28-jxjaWRW9dGdzXxLQ49BRJEnc_3imxN-
  RZva5dbD4m8_maOwhUguFAhu_adT0-Exm7xbV2x3MhnOXIVXZHDfH5WctsyLEdz7VUJ1lo
  1WBj5C0b4WWvN07TuykyMtqdz2NzUEVF7qpV25AeQ8JPAAuMLgtNMRbqgPLDPbBzhd.oN
  RI0P8elhhtgeCgDj1vTw; proximity_42f1666c716c8562437e6a02ebefc081=
  eyJ6aXAiOiJERUYiLCJ2ZXIIOiJ5SUZUSmpaW19aVmXkemIt2TdYmZVnIiwicDJIjoi
  AwLWJ2ZXIIOiIiIiwiaWxpYXkiOiJBMjU2R0NNIiwiaWF0Ijoi2GlyIiwiaWNTNTYy
  VyJ9.cYLUuT7JaaKnTcndrWnKRC9CdiRGnawB0PQwU5kEJW7jjo7GnXQ.vrfGykcL5W
  ewNjJs.bUCSNGnph16GFH5pbj8spc-8fb1nFTx5sJxsf4Gsdet_PYxBP4V9eHMFjYyIv
  Pp2uE83ImDgZTFKcsi7wdd2hoOztQqrc908pIYwDzqfZFLJyfrzkJ49-FCuLbyxendulQ
  MpyZazSTUC2v8Bqio88rc_dOHdk-9VR50U9hrCc9g.uTQgDesf7CrfHsASsqiH8A;
  JSESSIONID=5FCd5C97D881420085641AB85D1F24
4 Sec-Ch-UA: "Not:A-Brand";v="24", "Chromium";v="134"
5 Sec-Ch-UA-Mobile: ?0
6 Sec-Ch-UA-Platform: "Windows"
7 Sec-Ch-UA-Platform-Version: ""
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 400 Bad Request
2 Server: awselb/2.0
3 Date: Mon, 07 Jul 2025 08:29:59 GMT
4 Content-Type: text/html
5 Content-Length: 122
6
7 <html>
8   <head>
9     <title>
10      400 Bad Request
11    </title>
12   </head>
13   <body>
14     <center>
15       <h1>
16        400 Bad Request
17      </h1>
18     </center>
19   </body>
20 </html>
```

Instance 3: (Informational)**Screenshots:**

120 https://kpmgstaging.kerberos.oktapreview.com/login/agentlessDso/interact?precheck=false&interactionHandle=eDlzd0ZhTU9XQWo... GET 200 ✓ 22246 HTML 75.232.98

Request Response

Pretty Raw Hex Render

1 HTTP/2 200 OK
2 Date: Mon, 07 Jul 2025 07:20:26 GMT
3 Content-Type: text/html; charset=utf-8
4 **Server: nginx**
5 Vary: Accept-Encoding
6 X-Okta-Request-Id: 0e8648b38e10b695f6a405400bd848e2
7 Accept-Ch: Sec-CH-UA-Platform-Version
8 X-Xss-Protection: 0
9 P3p: CP="HONK"
10 Set-Cookie: xids="";Version=1;Path=/;Max-Age=0
11 Content-Security-Policy-Report-Only: default-src 'self' kpmgstaging.oktapreview.com *.oktacdn.com; connect-src 'self' kpmgstaging.oktapreview.com kpmgstaging-admin.oktapreview.com *.oktacdn.com *.mixpanel.com *.mapbox.com kpmgstaging.kerberos.oktapreview.com kpmgstaging.mtls.oktapreview.com *.authenticatorlocalprod.com:8769 http://localhost:8769 http://127.0.0.1:8769 *.authenticatorlocalprod.com:65111 http://localhost:65111 http://127.0.0.1:65111 *.authenticatorlocalprod.com:65121 http://localhost:65121 http://127.0.0.1:65121 *.authenticatorlocalprod.com:65131 http://localhost:65131 http://127.0.0.1:65131 *.authenticatorlocalprod.com:65141 http://localhost:65141 http://127.0.0.1:65141 *.authenticatorlocalprod.com:65151 http://localhost:65151 http://127.0.0.1:65151 https://oimmanager.okta.com data: *.ingest.sentry.io; script-src 'unsafe-inline' 'nonce-y32UoaQVv7lJuRPPFW7w5w' 'unsafe-eval' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com; style-src 'unsafe-inline' 'nonce-v32UoaQVv7lJuRPPFW7w5w' 'self' 'report-sample' kpmgstaging.oktapreview.com *.oktacdn.com;

Server: nginx 1 match

Instance 4: (Informational)**Screenshots:**

Send

Cancel

<

>

Target: <https://kpmgstaging.kerberos.oktapreview.com> HTTP/2

Request

Pretty Raw Hex

1

Trace /login/agentlessDso/interact?precheck=false&interactionHandle=d12QT2V5UGxqY2MvSUpu2z1NY1FtdU8vdGgxM3pxRXZ2POVJnUT1LNzBWz2FtQW0rN22YdXJVCpdlRfdaOXFpag HTTP/2

2

Host: kpmgstaging.kerberos.oktapreview.com

3

Cookie: JSESSIONID=9f88f8e5b8cedbb982417a8ef6f6aade; DT=DI1b2G-ck9jRjOrBpxQ871rQg

4

Authorization: Negotiate

YIIqagYgKwYBBQUCoIIqKjCCKlqgMDAuBgkqhkiC9xIBAgIGCSqGSIb3EgEAgYFKWYBBA

GcNwIChgYFKwYBBAGNwICQKCR1QBgioYIIqHAYJKoZIhvcSAQICAQBugioLMIICQBBAD

AgBFOQMAQ6IbWMAAACAACjgiHjYIIoXzCCKFugAwIBBAEUGxJVUy5LV09STEQuS1BNRy

5DT02InZAlOAMCAQKhLjAsGwRIVFRQgyRrcGlnC3Rh22lu2y5rZXJiZXJvcy5va3RhcHJl

dm1ldy5jb22jgiDMIIIn/6ADAgESoQMAQSigifxBIIn7fwqMuHtceGrj13pKpaXMOaQpr

fIAIoVkUy8N0qWqTBIIX5gmXWLSOvhX9Aax4v/DvVHBSQ4m8LxWLdG/w34hkMh9WUUGZT

RxLvZ41/Mu+fdLqRbQ32U1Fb6k0ppJXkdJGWeaBDX+9Qw4umOKc7SvyeYT3WCi8yK0TptS

vGYjxwpgMH9dsdIizrP4bYH4d10EUeK9kMzjqFuSuVcWYJ3MgHjngG4VvethoSvUOH1EKm

oWmUdpzFw6cpb6FqlcMyDBIH0he4o9zWcG2+IpeOaBf2MIbd5+mUy6pp+lpOErhT1tbljn

mXhvcf2TBG8JAA3pKH3A5bSHnr+2+jcLbzoGSLWqBoRFP3kgCYB1hd2XmhplUCFgmHsJ6B

HK5FP3CmjvmnFRdxhBw4eXwcoBH0bdw5DHDedQ3zXZFnPIWUXHtSdoXudipdU0lvj19Qv

z5khxCpAnx93hI6ceTkpt887i/rNtbjTV5klLujn6sube9me3LtrdIdv+40I5jNGoGVjp

xWKPcJ6QocnBUJkZ+J1tjJhu9wksxLyIqHs+dKzNhIEOM4jV/moibhhqsUHI1ls6BFFs/X

kHG293XKI4+x+bLXw6c8YpzdVkiG8a/J0D3j/SY/56JqA5xCoJbqXhcSzm4P6Av2vcUPD

6wpAHg9vFM7j02+q/1HY12TJqpcBbwFEIasFKaIH+Pd/ikkevDDRkyMJK+ysH3vt6PLG56

9dk68wtfn9veF13jkMM11IqjVxsannvtToePBdnc1qMqQ2mTpC8mszVZr3azYarSO/OF9t

sq3tDqCPMDwHetBd4eNgeWNvriJ/5EirrfvgHNV32CdT23t0k+Ap6bGT2t7Xs1JyoVgAW5

4N1NCT0njp+X/qfP1fJnx8nuM2f/qACjvuUIn7H0azTxKlMSL+u9f0rFDNppOVHLY7cC/H

K9Grjn4I6e15TmCUN0M7ghNnN7gaWVGB8XJvDJ71jCBUOp3BaoRYMMVAuci5MV+umgowf

tQ2U1ZLmn1EmMLx/FTvLSuFAaEt0xtUhgdd3wpoignFYFNOZP0fBM8cFC2w+p5wHgwgyu9

21ek+8Y539FABE49AcMwXGhahpUJAohzIGS531JuegppEn6n2Tu0cQzCAv96U3d26mKQS

jNxmSMZYcBEYpKF/8gW16Iyq1ROQ/r2TvQbtj2kw6ayGcelXwEMqoYQyBkcoUoqtRztOTp

e4sT2vi2FZW2a/FDYHf31+13MnwFe0SvVAVaGORXZ+R40aoDJPOaWYBcNNDibYIbif+JAm

Response

Pretty Raw Hex Render

1

HTTP/2 400 Bad Request

2

Server: awselb/2.0

3

Date: Mon, 07 Jul 2025 08:51:17 GMT

4

Content-Type: text/html

5

Content-Length: 122

6

7

<html>

8

<head>

9

<title>

10

400 Bad Request

11

</title>

12

</head>

13

<body>

14

<center>

15

<h1>

16

400 Bad Request

17

</h1>

18

</center>

19

</body>

20

</html>

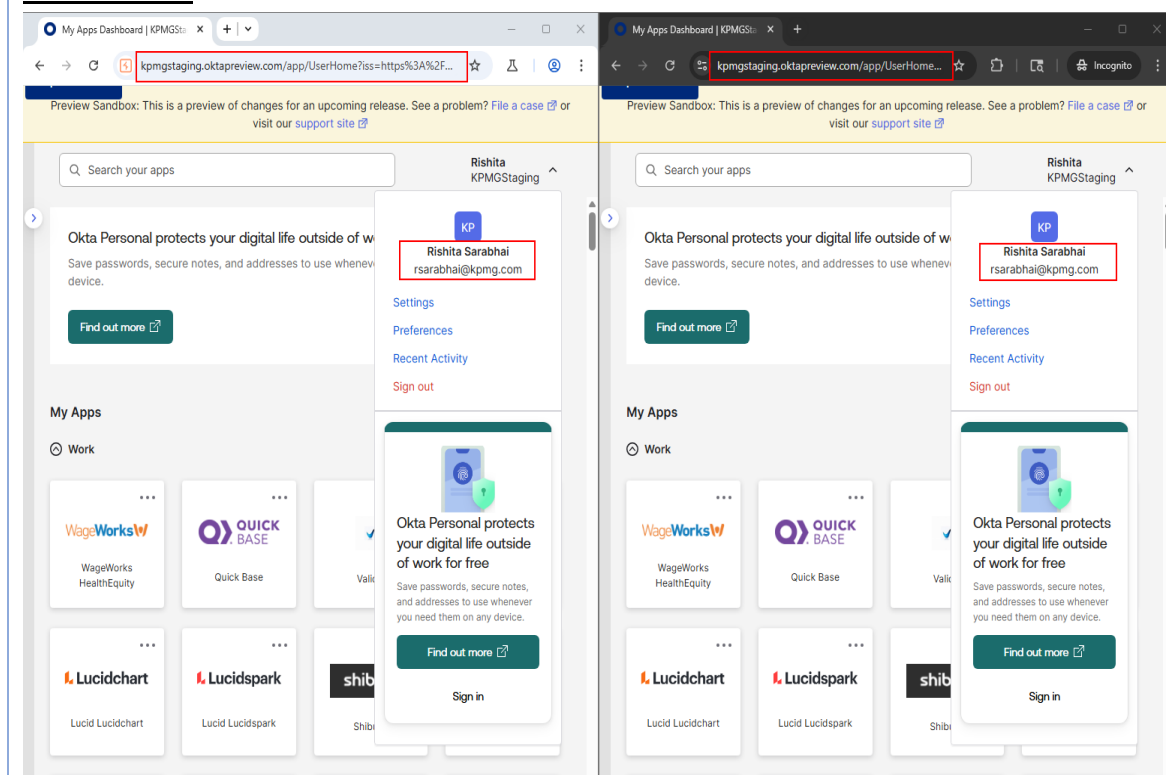
Remediation

Remove all unnecessary HTTP Headers.

(Closing/Down grading)

Justification

Vulnerability	11. Concurrent User Session		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	It is the web application design decision to determine if multiple simultaneous logons from the same user are allowed from the same or from different client IP addresses. If the web application does not want to allow simultaneous session logons, it must take effective actions after each new authentication event, implicitly terminating the previously available session, or asking the user (through the old, new or both sessions) about the session that must remain active.			
URL	https://kpmgstaging.oktapreview.com/app/UserHome?iss=https%3A%2F%2Fkpmgstaging.oktapreview.com&session_hint=AUTHENTICATED			

Screenshots:**Remediation**

It is recommended for web applications to add user capabilities that allow checking the details of active sessions at any time, monitor and alert the user about concurrent logons, provide user features to remotely terminate sessions manually, and track account activity history (logbook) by recording

	multiple client details such as IP address, User-Agent, login date and time, idle time, etc. There are two possible ways to have your applications handle a login attempt that exceeds the allowed number. The default is that previous sessions are invalidated and if the user tries to use his initial session he will be redirected to “your-page-here”. This is probably best for most applications. The other option is to throw an exception after the login attempt and keep the former session(s) valid. To do that, add the attribute error-if-maximum-exceeded="true" to the <concurrency-control/>.
(Closing/Down grading) Justification	

Vulnerability	12. CBC-mode Encryption in TLS (Lucky 13 attack)		Status	Open
Risk Rating	Informational	Vulnerability Owner	Okta	
Issue Description:	A vulnerability exists in the TLS and DTLS protocols that may allow an attacker to recover plaintext from TLS/DTLS connections that use CBC-mode encryption. The attacks apply to all TLS and DTLS implementations that are compliant with TLS 1.1 or 1.2, or with DTLS 1.0 or 1.2. Tool Used: testssl.sh			
URL	<u>Instance 1:</u> https://kpmgstaging.oktapreview.com <u>Instance 2:</u> https://kpmgstaging.kerberos.oktapreview.com			

Instance 1: (Informational)**Screenshots:**

```

Start 2025-07-07 12:40:08 --> 99.83.191.34:443 (kpmgstaging.oktapreview.com) <--
rDNS (99.83.191.34): a71653d1ac0df114f.amazonaws.com
Service detected: HTTP

Testing vulnerabilities
Heartbleed (CVE-2014-0160) not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224) not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experiment. not vulnerable (OK), reply empty
ROBOT not vulnerable (OK)
Secure Renegotiation (RFC 5746) supported (OK)
Secure Client-Initiated Renegotiation ./testssl.sh: line 17421: pkill: command not found
not vulnerable (OK)
CRIME, TLS (CVE-2012-4929) not vulnerable (OK)
BREACH (CVE-2013-3587) no gzip/deflate/compress/br HTTP compression (OK) - only supplied "/" tested
POODLE, SSL (CVE-2014-3566) not vulnerable (OK)
TLS_FALLBACK_SCS (RFC 7507) No fallback possible (OK), no protocol below TLS 1.2 offered
SWEET32 (CVE-2016-2183, CVE-2016-6329) not vulnerable (OK)
FREAK (CVE-2015-0204) not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK)
make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=280576808C43E4F00D4C62BA248E86FCF8665D83779B212C9650F4F90C419311
LOGJAM (CVE-2015-4000), experimental not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with <= TLS 1.2
BEAST (CVE-2011-3389) not vulnerable (OK), no SSL3 or TLS1
LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses cipher block chaining (CBC) ciphers with TLS. Check patches
WinShock (CVE-2014-6321), experimental not vulnerable (OK) - CAMELLIA or ECDHE_RSA GCM ciphers found
RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)

Done 2025-07-07 12:58:08 [1408s] --> 99.83.191.34:443 (kpmgstaging.oktapreview.com) <--

```

Instance 2: (Informational)

Screenshots:

```

Start 2025-07-07 12:40:51 --> 75.2.32.98:443 (kpmgstaging.kerberos.oktapreview.com) <<--

rDNS (75.2.32.98): a71653d1ac0df114f.awsglobalaccelerator.com
Service detected: HTTP

Testing vulnerabilities

Heartbleed (CVE-2014-0160) not vulnerable (OK), no heartbeat extension
CCS (CVE-2014-0224) not vulnerable (OK)
Ticketbleed (CVE-2016-9244), experiment. not vulnerable (OK), reply empty
ROBOT not vulnerable (OK)
Secure Renegotiation (RFC 5746) supported (OK)
Secure Client-Initiated Renegotiation ./testssl.sh: line 17421: pkill: command not found
not vulnerable (OK)
CRIME, TLS (CVE-2012-4929) not vulnerable (OK)
BREACH (CVE-2013-3587) no gzip/deflate/compress/br HTTP compression (OK) - only supplied "/" tested
POODLE, SSL (CVE-2014-3566) not vulnerable (OK)
TLS_FALLBACK_SCSV (RFC 7507) No fallback possible (OK), no protocol below TLS 1.2 offered
SWEET32 (CVE-2016-2183, CVE-2016-6329) not vulnerable (OK)
FREAK (CVE-2015-0204) not vulnerable (OK)
DROWN (CVE-2016-0800, CVE-2016-0703) not vulnerable on this host and port (OK)
make sure you don't use this certificate elsewhere with SSLv2 enabled services, see
https://search.censys.io/search?resource=hosts&virtual_hosts=INCLUDE&q=E887F034B64E26CB6AE99AFD897EA009A3CB67BC5E43E488A3E084F41BFS9C26
LOGJAM (CVE-2015-4000), experimental not vulnerable (OK): no DH EXPORT ciphers, no DH key detected with <= TLS 1.2
BEAST (CVE-2011-3389) not vulnerable (OK), no SSL3 or TLS1
LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses cipher block chaining (CBC) ciphers with TLS. Check patches
Winshock (CVE-2014-8521), experimental not vulnerable (OK) - CAMELLIA or ECDHE_RSA GCM ciphers found
RC4 (CVE-2013-2566, CVE-2015-2808) no RC4 ciphers detected (OK)

Done 2025-07-07 12:58:46 [1405s] --> 75.2.32.98:443 (kpmgstaging.kerberos.oktapreview.com) <<--

```

Remediation

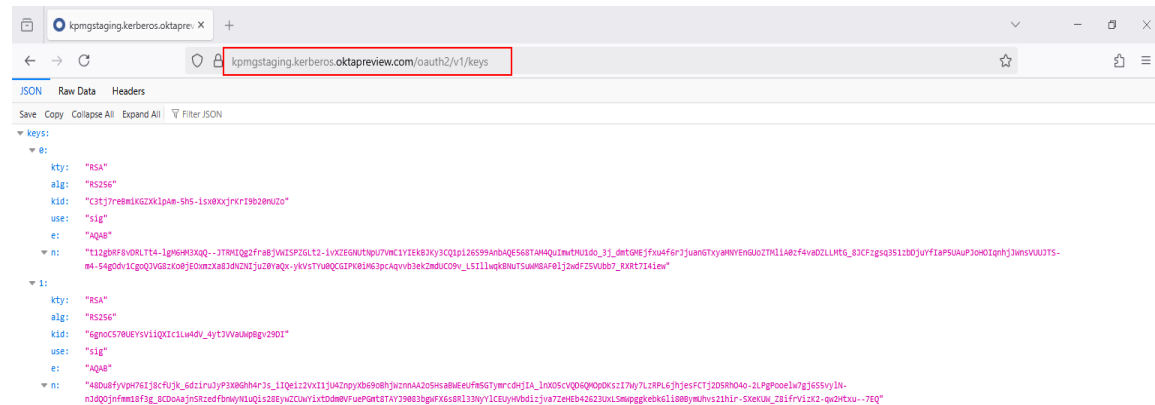
To mitigate potential exploit for SSL/TLS virtual servers, you can configure the SSL profile to prefer non-CBC ciphers.

**(Closing/Down
grading)****Justification**

38 | Page

Instance 2: (Informational)**Reproduction Steps:**

1. Open the target URL without any form of authentication

Screenshots:

Remediation	All unwanted files should be removed. If some files are required, then proper authorization control must be implemented so that those files are not available to everyone.
(Closing/Down grading) Justification	

4. Appendix

4.1. Appendix A – Application Risk Score Matrix

The Application Risk Score is calculated by assigning a Risk Score value of 1, 2 or 3 to the following three categories and then summing the three values:

- Location and Access Vector
- Data Classification
- Business Criticality

1. Location and Access Vector – The location where the application would be hosted is one of the key factors in determining the threat landscape for that application. Internally hosted applications i.e. Applications that are hosted on KNET generally have a much more controlled threat landscape and hence lower risk of exposure to attackers and malicious entities. The risk therefore is significantly lower in comparison to applications hosted in the DMZ or on an Internet server at an Application Service Provider (ASP) or a third-party.

2. Data Classification - Data classification is a very critical aspect of the application and is a key in determining the risk posture of the application. Data classification mainly deals with the confidentiality and integrity of the data. The KPMG Information System Classification Standard classifies data into 4 different categories:

- DC 0 – Systems that handle information that is made generally available to Public
- DC 1 – Systems that handle information that is made generally available to KPMG personnel
- DC 2 – Systems that handle sensitive information that is restricted based on group or individual access and need to know.
- DC 3 – Systems that handle extremely sensitive information that is restricted based on group or individual access and need to know

The application risk score matrix classifies data as Public or Internal, Confidential and Restricted and maps these 3 classes to the DC ratings as follows:

- Public or Internal / DC0 and DC1
- Confidential / DC2
- Restricted / DC3

Note: DC0 and DC1 map the same risk score, i.e., 1.

Applications hosting public data are considered to be at a lower risk level than those hosting confidential or restricted data. The classification standard also imposes certain control requirements. Although these are mostly data protection controls, those relevant to secure software development process are incorporated into the software security policy and associated control standards.

Please refer to KPMG Information System Classification Standard for more details.

3. Business Criticality – Business criticality mainly deals with availability of the data and the application and is the third key factor in determining the risk posture of the application. There are 4 levels of classifications for Business Criticality:

- BC 0 / Low Impact–Firm could lose revenue or reputation if the application is down for several months.
- BC 1/ Important- Firm could lose substantial revenue, reputation or control if the application is down for several weeks.
- BC 2 / Critical- Firm could lose substantial revenue or reputation if the application is down for several days.
- BC 3 / Essential- Firm could not do business and/or generate revenue for any length of time without the application thus jeopardizing the survival of the firm.

Note: BC0 and BC1 map to the same risk score, i.e., 1.

ARS Matrix and Calculating the ARS

Location/Access Vector	Data Classification	Business Criticality
Hosted Internally(KNET,TPC) (Value = 1)	Public or Internal(DC0&DC1) (Value =1)	BC0 & BC1 (Value= 1)
Hosted in DMZ (Value= 2)	Confidential(DC2) (Value = 2)	BC2 (Value= 2)
Hosted Externally(Internet Third-party) (Value= 3)	Restricted(DC3) (Value=3)	BC3 (Value=3)

Use the following formula to determine ARS:

Value 1 = Value assigned to the applicable class of the Location / Access Vector attribute

Value 2 = Value assigned to the applicable class of the Data Classification attribute

Value 3 = Value assigned to the applicable class of the Business Criticality attribute

ARS = Value 1 + Value 2 + Value 3

Example:

ARS for an application that is hosted internally handles confidential data and has a business criticality rating of BC2 will be calculated as:

Value 1 = 1 (Hosted Internally)

Value 2 = 2 (Confidential Data)

Value 3 = 2 (Business Criticality BC2)

ARS = Value 1 + Value 2 + Value 3 = 1 + 2 + 2 = 5

4.2. Appendix B – 5 STAR Assessment Rating System

The 5-star assessment rating provides information on the likelihood and impact of defects present within an application. A perfect rating within this system would be 5 stars indicating that no high impact vulnerabilities were uncovered.

	One star rating is awarded to projects that have minimum of 1 or more Critical severity issues. Critical severity issues are High Likelihood, High Impact
	Two STAR rating is awarded to projects that have minimum of 1 or more High severity issues but no Critical severity issues. High severity issues are Low Likelihood, High Impact
	Three STAR rating is awarded to projects that have minimum of 1 or more Medium severity issues but no Critical or High severity issues. Medium severity issues are High Likelihood, Low Impact
	Four STAR rating is awarded to projects that have minimum of 1 or more Low severity issues but no Critical, High or Medium severity issues. Low severity issues are Low Likelihood, Low Impact
	Five STAR rating is awarded to projects that have no security issues

4.3. Appendix C – Terminology

Critical

Critical-priority issues have high impact and high likelihood. Critical-priority issues are easy to detect and exploit and result in large asset damage. These issues represent the highest security risk to the application. As such, they should be remediated prior to the go live date for applications or functionalities not yet in production. Applications with vulnerabilities already in production should fix critical priority issues within 5 days from the Preliminary Report date.

High

High-priority issues have high impact and low likelihood. High-priority issues are often difficult to detect and exploit, but can result in large asset damage. These issues represent a high security risk to the application. High-priority issues should be remediated prior to the go live date for applications or functionalities not yet in production. Applications with vulnerabilities already in production have 30 days from the Preliminary Report date to fix high priority issues.

Medium

Medium-priority issues have low impact and high likelihood. Medium-priority issues are easy to detect and exploit, but typically result in small asset damage. These issues represent a moderate security risk to the application. Medium-priority issues should be remediated prior to the go live date for applications or functionalities not yet in production. Applications with vulnerabilities already in production have 60 days from the Preliminary Report date to fix Medium priority issues.

Low

Low-priority issues have low impact and low likelihood. Low-priority issues can be difficult to detect and exploit and typically result in small asset damage. These issues represent a minor security risk to the application. Low-priority issues should be remediated in the next scheduled product update.

Informational

Informational findings are observations during application pen tests that may not possess exploitable security risks within an application at the time. These kind of findings may be related to best practices as per industry standards or unusual behavior from application. Informational findings do not have defined remediation SLA.

4.4. Appendix D – Methodology for Application Assessment

Application Foot printing – This phase identifies all applications running on particular client's infrastructure. Various tools are used to identify IP blocks, Hosts, Domains, Cross-domains and Child-domains using various tools. This helps in identifying all possible targets.

Application Discovery – In this phase all accessible applications running on client's infrastructure are identified.

Application Threat Modeling – In this phase each application is studied and all critical information is mapped. This helps to define objectives, dependencies, type of servers (web, application and database), roles, components, third-party blocks and use cases. It also helps to identify possible threat matrix and attack vectors.

Application Enumeration and Profiling – In this phase several tools are used to enumerate the target application. This helps in profiling the entire application, gathering information regarding modules, functionalities and resource attributes.

Security Control and Test Cases – A large repository of test cases and security controls required for applications is used as a guide for the application assessment. This is primarily based on OWASP and CWE industry standard and it helps to build up all test methodologies against known vulnerabilities.

Some of the security control categories we check for include the following:

- Information Gathering
- Configuration Management
- Authentication
- Authorization and Access Control
- Session Management
- Input Validation
- Encryption

Vulnerability Assessment – A complete vulnerability scanning is done using manual testing. This covers all the applicable security control test cases and ensures that all vulnerabilities on the application is detected.

Exploitation and Pen-testing – A full blown penetration and exploitation of discovered vulnerabilities is performed to detect the severity and possible impact of existing vulnerabilities.

Mitigation Strategies: Based on overall findings, a comprehensive plan for mitigation along with recommendation on secure coding best practices is provided. These strategies need to be implemented for overall security of application.

Reporting – All observations, findings, test cases and recommendations are documented in the final report. A risk rating is assigned to each discovered vulnerabilities based on CVSS v2 and CWE.

4.5. DSG Disclaimer Notice

Cybersecurity threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much security testing is conducted. This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. DSG offers no warranties, representations or legal certifications concerning the applications or systems it tests.

All software includes defects: nothing in this document is intended to represent or warrant that security testing was complete and without error, nor does this document represent or warrant that the application tested is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. By using this reported information you agree that DSG shall be held harmless in any event.

Non-Production and Production Testing Advisory

It is important for the customer to understand that the engagement testing in non-production environments such as UAT (User Acceptance Testing) or QC (Quality Control) represents what is found only in such environments. If there are inaccuracies, omissions, or changes made during or after the testing engagement; this may impact findings visibility and ultimately the accuracy of this report. It is equally important to note that UAT and QC environments should ultimately mimic the production environment. DSG pen testers, unless at the request of the customer do not typically perform testing within a production environment for general stability and safety concerns. If production testing is a requirement by the SRM (Security Relationship Manager), please create a separate PTI (Penetration Testing Intake) form for as such and notify the DSG pen testers.

Modifications during Testing Engagements

If the customer performs any modifications or changes to the testing environment during an engagement, this may adversely impact the accuracy of the report and findings. Customers should be prepared to freeze changes where possible. If not possible, please notify the DSG pen testers of the intended change, time of change, and to which assets it will affect.